

Nmap: Esplorazione Rete & Audit di Sicurezza

Riferimento Modulo: U3_S11_L5 — Domande Bonus 1

1. Concetti Fondamentali

D: Cos'è Nmap?

È uno strumento gratuito e open-source utilizzato per l'esplorazione delle reti e il controllo della sicurezza informatica.

D: Per cosa viene usato Nmap?

Viene impiegato principalmente per la scansione delle reti (*network discovery*) e per l'esecuzione di audit di sicurezza informatica.

2. Sintassi del Comando e Parametri

D: Qual è il comando Nmap utilizzato nell'esercizio?

```
nmap -A -T4 scanme.nmap.org
```

D: Cosa fa l'opzione -A?

Attiva una **scansione aggressiva** (*Aggressive Scan*). È un'opzione "all-in-one" progettata per raccogliere il maggior numero possibile di informazioni su un bersaglio con un solo comando, abilitando contemporaneamente:

- **Rilevamento del Sistema Operativo** (`-O`): Tenta di individuare il sistema operativo installato (Windows, Linux, macOS, ecc.).
- **Scansione della versione dei servizi** (`-sV`): Identifica i programmi esatti e le relative versioni sulle porte aperte.
- **Scansione con script NSE** (`-sc`): Esegue gli script predefiniti di Nmap per rilevare vulnerabilità note e raccogliere dettagli extra.
- **Tracciamento del percorso** (`--traceroute`): Mostra la sequenza di nodi e router attraversati dai pacchetti.

D: Cosa fa l'opzione -T4?

Regola la velocità e la frequenza delle richieste inviate da Nmap, impostando il livello di temporizzazione (*Timing*) su **Aggressive** per velocizzare l'analisi.

3. Risultati dell'Analisi di Scansione

D: Dettagli del Target e Risultati Scansione (`scanme.nmap.org` e Rete Locale)

PARAMETRO / QUESITO	VALORE / RISPOSTA
Scopo del sito target	Verificare la corretta installazione e il funzionamento di Nmap.
Indirizzo IP del Server Target	<code>45.33.32.156</code>
Sistema Operativo Rilevato	Ubuntu Linux
Porte & Servizi Aperti (Target)	<code>22/tcp</code> - OpenSSH <code>53/tcp</code> - dnsmasq <code>80/tcp</code> - Apache httpd <code>9929/tcp</code> - Nping echo <code>31337/tcp</code> - tcpwrapped
Porte Filtrate	Nessuna porta risulta filtrata.
Rete della VM locale	<code>192.168.64.0/24</code>
Host Attivi nella Rete VM	<code>192.168.64.1</code> e <code>192.168.64.13</code> (esattamente i due host specificati)
Porte/Servizi Aperti (Rete Locale/ VM)	<code>21</code> (vsftpd), <code>22</code> (OpenSSH)

4. Dual-Use: Uso Difensivo vs Uso Offensivo

Uso Difensivo (Blue Teaming)

- **Inventario degli Asset:** Identifica tutti i dispositivi collegati (server, IoT, workstation), eliminando i punti ciechi.
- **Mappatura dei Servizi:** Rileva porte e servizi attivi per ridurre la superficie di attacco (*attack surface*).
- **Fingerprinting del Software:** Determina le versioni esatte per individuare software obsoleti o vulnerabili.
- **Audit con NSE:** Esegue script automatizzati per rilevare misconfigurazioni e credenziali di default.
- **Verifica Firewall:** Testa le regole di filtraggio e le ACL per confermare il blocco del traffico non autorizzato.

Uso Offensivo (Red Teaming / Attaccanti)

- **Ricognizione e Mappatura:** Individua gli host attivi e la topologia di rete per scegliere i bersagli.
- **Vettori d'Ingresso:** Trova servizi di gestione remota (RDP, SSH) esposti per errore su Internet.
- **Targeting di Vulnerabilità:** Cerca exploit specifici basandosi sulle versioni esatte dei servizi scoperti.
- **Evasione IDS/IPS:** Sfrutta frammentazione pacchetti, scansioni *decoy* (esche) e timing lento (`-T0/-T1`).
- **Ingegneria Sociale:** Raccoglie nomi dominio e dettagli tecnici per strutturare attacchi di phishing mirati.